Федеральное государственное автономное
образовательное учреждение высшего образования

«Национальный исследовательский университет ИТМО»

ЛАБОРАТОРНАЯ РАБОТА № 7

по дисциплине

«Информационная Безопасность»

Выполнил:
Носов Георгий Иванович
Группа: P3432

Преподаватель:

Рыбаков Степан Дмитриевич

г. Санкт-Петербург
2026

Содержание

Содержание 2

1. Задание 2

2. Анализ и настройка параметров безопасности браузера. 3

3. Проведение анализа сетевого трафика, формулирование вывода о передаче данных. 4

4. Выводы 7

1. Задание

1. **Настройка браузера:** тщательно изучите настройки безопасности и конфиденциальности вашего браузера (например, Chrome или Firefox). Включите расширенную защиту от отслеживания, отключите сохранение паролей в браузере, почистите куки и кэш.

2. **Анализ трафика:** Откройте в браузере "Инструменты разработчика" (F12), перейдите на вкладку "Сеть" (Network). Откройте любой сайт. Проанализируйте список HTTP-запросов: найдите запросы типа GET/POST, посмотрите, какие данные передаются в заголовках (headers).

3. Найдите на каком-нибудь сайте форму входа и попробуйте ввести тестовые данные. Посмотрите в инструментах разработчика, как передается логин и пароль (в открытом виде или зашифровано?).

2. Анализ и настройка параметров безопасности браузера.

В рамках исследования параметров безопасности на стороне веб клиента мы посмотрели конфигурацию встроенного браузера Safari в операционной системе macOS. В разделе настроек «Конфиденциальность» были активированы встроенные механизмы защиты от несанкционированного отслеживания и профилирования:

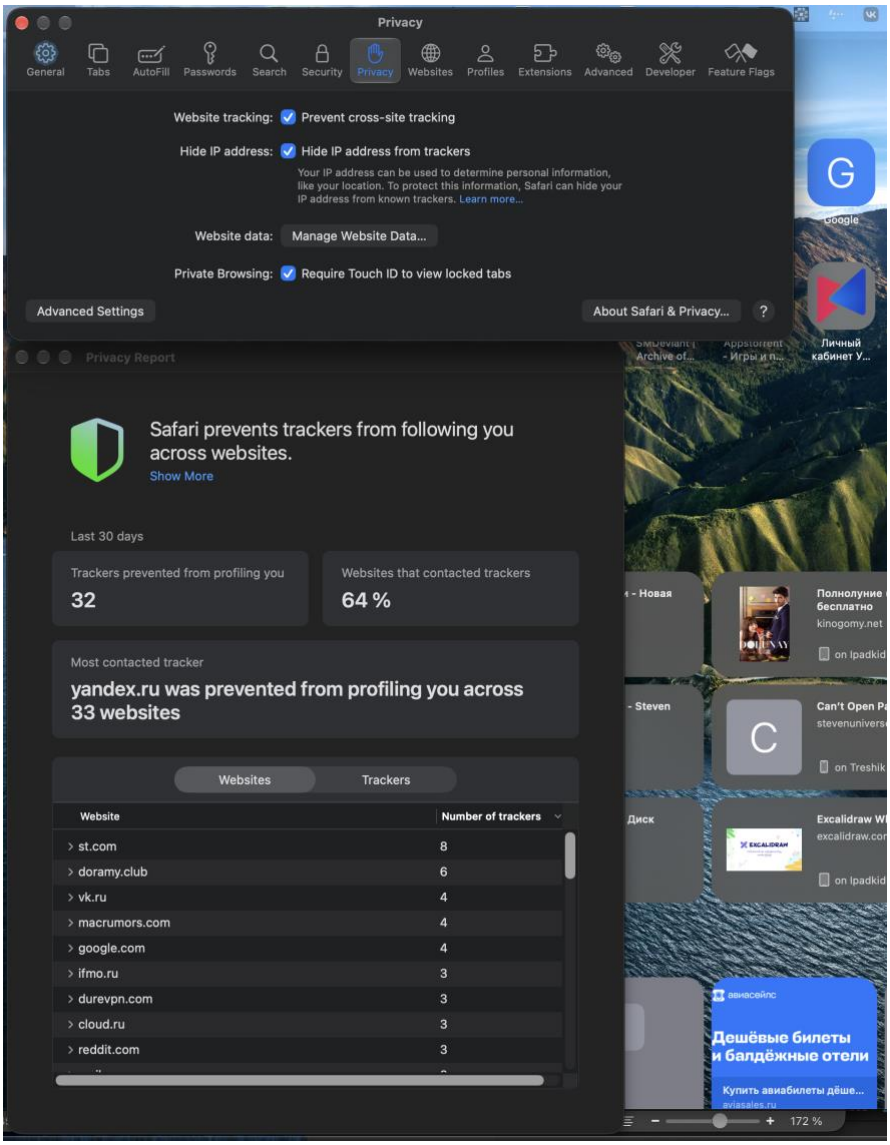


Рисунок 1. Конфигурация параметров конфиденциальности и защиты от сетевого отслеживания в браузере Safari

1. Предотвращение перекрёстного отслеживания: задействована технология Intelligent Tracking Prevention на основе локального машинного обучения. Механизм автоматически выявляет домены, используемые исключительно для отслеживания пользователей, и изолирует либо блокирует сторонние куки файлы (Third-party Cookies), а также очищает идентификаторы кликов в URL-ссылках.

2. Скрытие IP-адреса от трекеров: сетевые обращения к известным трекинговым платформам маршрутизируются через двухзвенную распределенную систему прокси-серверов Apple iCloud Private Relay, в результате чего ни сайт, ни трекер не получают доступа к исходному публичному IP-адресу пользователя. ;(

3. Расширенная защита от снятия цифрового отпечатка: браузер возвращает стандартизированные системные параметры и ограничивает доступ к API WebGL, Canvas и AudioContext, препятствуя формированию уникального отпечатка устройства (Device Fingerprint) без использования cookies.

3. Проведение анализа сетевого трафика, формулирование вывода о передаче данных.

Для исследования реального сетевого трафика и анализа структуры клиент-серверного взаимодействия был задействован встроенный инструмент разработчика Safari Web Inspector. В качестве исследуемого ресурса мы взяли сайт соцсети ВКонтакте (https://vk.ru/feed).

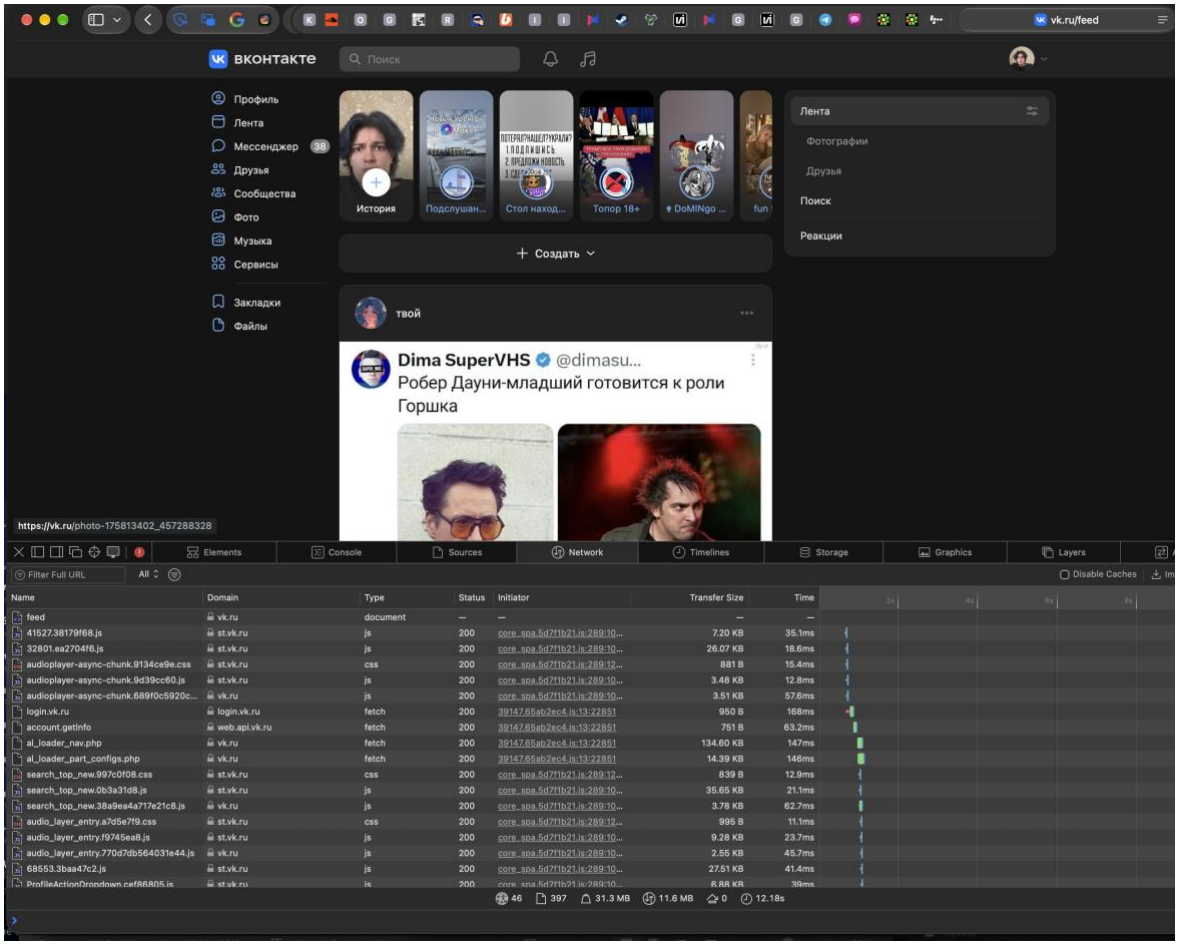


Рисунок 2. Анализ сетевых запросов при загрузке ленты новостей vk.ru

В процессе загрузки новостной ленты было зафиксировано 397 сетевых запросов общим объемом 31.3 МБ. Архитектура приложения функционирует как Single Page Application (SPA): после загрузки базового DOM-дерева веб-клиент отправляет параллельные асинхронные fetch/XHR запросы к распределенным шлюзам API (web.api.vk.ru, login.vk.ru, st.vk.ru) для подгрузки динамического контента, стилей и скриптов.

Сравнительный анализ ключевых перехваченных запросов систематизирован в Таблице 1.

№	Запрашиваемый ресурс (URL)	Метод и статус	Протокол и порт	Анализ безопасности
1	https://vk.ru/feed	GET, 200 OK	HTTPS (TLS 1.3), порт 443	Загрузка базового HTML документа SPA. Все содержимое страницы шифруется сессионным ключом TLS.
2	https://st.vk.ru/.../audio player-async-chunk.css	GET, 200 OK	HTTPS (TLS 1.3), порт 443	Статический стилевой файл из сети CDN. Гарантируется защита от MITM-подмены содержимого.
3	https://vk.ru/wkview.php	POST, 200 OK	HTTPS (TLS 1.3), порт 443	Передача сессионных маркеров (remixsid, remixnsid). Заголовки и Payload защищены сквозным шифрованием.
4	https://api.vk.ru/method /auth.checkAuthCode	POST, 200 OK	HTTPS (TLS 1.3), порт 443	Передача одноразового проверочного кода авторизации (2FA OTP) в защищенном теле запроса.

Таблица 1. Сравнительный анализ перехваченных сетевых запросов в Safari Web Inspector

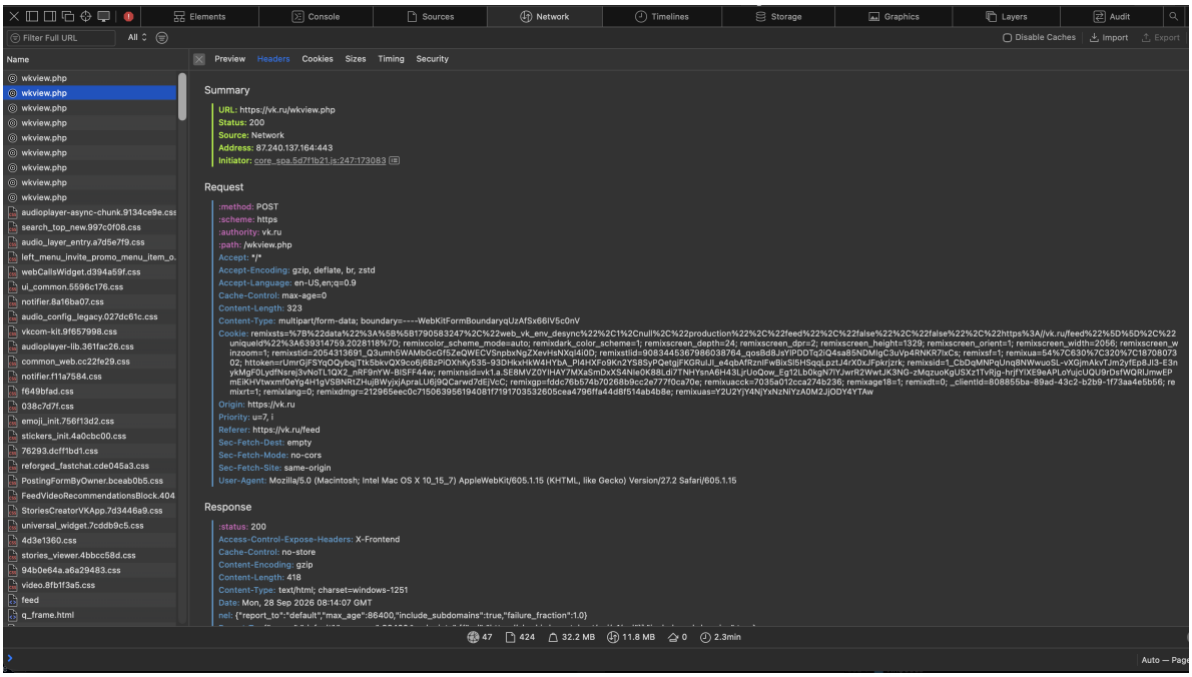


Рисунок 3. Анализ защищенного POST-запроса с cookie-файлами

Детальный анализ структуры защищенного POST-запроса wkview.php демонстрирует передачу данных на адрес 87.240.137.164:443 по протоколу HTTPS. В теле запроса типа multipart/form-data и HTTP-заголовках передаются критические маркеры сессии пользователя:

1. remixsid и remixnsid — уникальные идентификаторы активной сессии пользователя, дающие полный доступ к аккаунту без повторного ввода пароля.

2. httoken — защитный маркер для предотвращения атак межсайтовой подделки запросов (CSRF).

3. Cache-Control: директива, предписывающая браузеру не кэшировать конфиденциальный ответ сервера.

Благодаря протоколу TLS 1.3 все заголовки, cookie-файлы и полезная нагрузка шифруются симметричным шифром AES-GCM (с предварительным асимметричным обменом ключами ECDHE). Любой внешний наблюдатель в локальной сети видит только зашифрованные фреймы и IP-адрес сервера, но не может прочитать значения сессионных cookie.

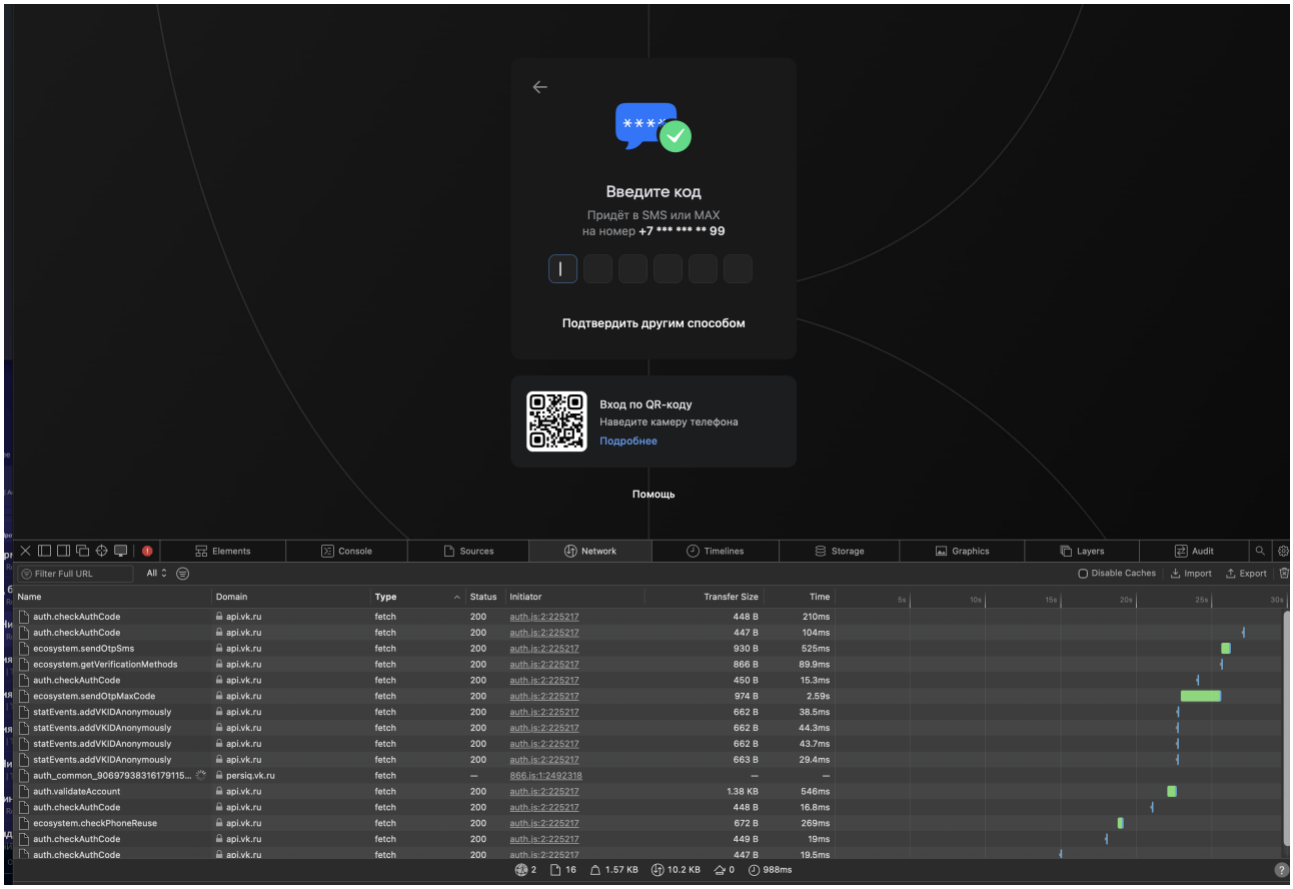


Рисунок 4. Перехват и анализ последовательности сетевых запросов авторизации VK ID (2FA OTP)

На Рисунке 4 мы пытались зафиксировать процесс авторизации в VK ID. При попытке входа веб-клиент отправляет серию защищенных API-запросов к api.vk.ru: auth.validateAccount (проверка учётной записи), ecosystem.sendOtpSms и ecosystem.sendOtpMaxCode (отправка одноразового смс кода на номер +7 [redacted] 99 или в MAX), а также auth.checkAuthCode (верификация введённого кода). Данные передаются исключительно по HTTPS в теле запросов, что исключает их раскрытие.

Но, к сожалению, после ввода кода сайт автоматически за секунду перезагружает страницу и успешно авторизуется, поэтому часть запросов по авторизации перехватить не удалось.

- **Ответ на вопрос: Как чаще всего передаются данные аутентификации (логин/пароль) в современных веб-приложениях?**

В современных веб-приложениях данные аутентификации никогда не передаются в открытом незашифрованном виде, для этого обязательно используется защищенное шифрованное соединение TLS/HTTPS, которое защищает учётные данные от перехвата в сети, путём мониторинга трафика. Сама отправка формы авторизации всегда происходит в теле запроса методом POST, что исключает попадание конфиденциальной информации в адресную строку браузера, историю или логи прокси-серверов, что по сравнению с GET безопаснее от некоторых стратегий перехвата.

После того как сервер проверяет переданные данные, он выдаёт клиенту короткоживущие сессионные токены (например, JWT или OAuth 2.0), которые в дальнейшем используются для всех запросов, а сам пароль в этих операциях больше не участвует. Эти токены обычно безопасно сохраняются в защищенных от доступа скриптов cookie файлах с флагами HttpOnly и Secure. Кроме того, современные системы постепенно внедряют беспарольные стандарты авторизации вроде Passkeys, полностью исключающие передачу паролей по сети.

4. Выводы

В ходе выполнения лабораторной работы мы изучили основные настройки конфиденциальности браузера и на практике посмотрели на сетевой обмен веб-приложения через инструменты разработчика. Убедились в том, что современный веб (контора ВКонтакте) опирается на обязательное шифрование трафика (HTTPS), а правильная передача авторизационных данных и сессионных куки защищает пользователя от перехвата информации в сети.